# Gobuster - The Basics

*Mastering Automated Enumeration and Reconnaissance*

**Gobuster** is an open-source offensive security tool written in **Golang**, specifically designed for high-performance **Enumeration** via brute force. In the reconnaissance phase of a penetration test, Gobuster is used to uncover hidden resources that are not linked publicly, such as web directories, hidden files, **DNS subdomains**, and **Virtual Hosts**. By utilizing extensive **Wordlists**, it programmatically guesses names and analyzes the server's **HTTP Status Codes** to identify valid resources. This module covers the installation, core operating modes (dir, dns, vhost), and essential flag configurations required to perform precise and efficient discovery on a target infrastructure.

This **documentation** and **learning** approach is strongly inspired by the structured, hands-on content provided by **TryHackMe**, which significantly contributed to practical understanding of "Gobuster Tool" concepts.

**DOCUMENTED BY**

Kaustubh Ghosalkar aka "WEIRDO"

LINKEDIN GITHUB

# 1. Core Concepts: Enumeration and Brute Force

Before operating the tool, it is essential to understand the underlying methodology:

- **Enumeration:** The process of listing all available resources on a target, whether they are intended to be public or not.
- **Brute Force:** In this context, it refers to trying every entry in a **Wordlist** against a target until a match (e.g., a "200 OK" status) is found.

# 2. Gobuster Operating Modes

Gobuster is a multi-functional tool with three primary modes used in web and network assessments.

| Command | Mode Name | Purpose | Target Example |
|---|---|---|---|
| **dir** | Directory/File | Finds hidden folders and files. | http://example.thm/admin |
| **dns** | DNS Subdomain | Finds subdomains via DNS queries. | dev.example.thm |
| **vhost** | Virtual Host | Finds different sites on the same IP. | internal.site.local |

# 3. Directory and File Enumeration (dir)

The dir mode is used to discover the structure of a website. It appends words from a wordlist to the target URL to see if the path exists.

**Essential Flags for dir Mode**

- **-u**: Specifies the **Target URL**.
- **-w**: Path to the **Wordlist**.
- **-x**: Searches for specific **File Extensions** (e.g., .php, .txt, .js).
- **-k**: Skips **TLS/SSL Verification** (useful for self-signed certificates).
- **-r**: Instructs Gobuster to **Follow Redirects**.
-

### Command Section: Directory Scanning

**Basic Scan:**

```
gobuster dir -u http://10.10.10.10 -w /usr/share/wordlists/dirb/common.txt
```

**Scanning for Specific Files:**

```
gobuster dir -u http://example.thm -w list.txt -x .php,.html,.zip
```

- *Explanation:* This will try to find login.php, index.html, or backup.zip based on the wordlist entries.

WEIRDO

# 4. DNS Subdomain Enumeration (dns)

This mode is used to find subdomains (e.g., api.example.com) by sending DNS queries. Unlike dir mode, it does not communicate over HTTP but talks to **DNS Resolvers**.

**Key Requirements**

- **-d**: Specifies the **Target Domain**.
- **-i**: Shows the **IP Addresses** that the subdomains resolve to.

**Command Section: Subdomain Discovery**

```
gobuster dns -d example.thm -w
/usr/share/wordlists/SecLists/Discovery/DNS/subdomains.txt
```

- *Example Result:* Found: dev.example.thm, Found: support.example.thm.

# 5. Virtual Host Enumeration (vhost)

**Virtual Hosts** (vhosts) are multiple websites hosted on a single server/IP. While they often look like subdomains, vhost mode finds them by changing the **Host Header** in an HTTP request rather than querying a DNS server.

**Advanced Filtering**

Because many servers return a "200 OK" or a "404" with the same page size for every guess, we use **--exclude-length** to filter out false positives.

**Command Section: Vhost Discovery**

```
gobuster vhost -u http://10.10.10.10 -w list.txt --append-domain --domain example.thm --
exclude-length 300-350
```

- **--append-domain**: Adds the main domain to every word in the list (e.g., test becomes test.example.thm).
- **--exclude-length**: Ignores responses that have a specific character count.

WEIRDO

## 6. Configuration Performance Flags

To optimize the speed and stealth of your scans, use the following global flags:

| Flag | Name | Description | Beginner Tip |
|---|---|---|---|
| **-t** | **Threads** | Number of concurrent requests. | Default is 10; use 50-64 for faster local scans. |
| **--delay** | **Delay** | Time to wait between requests. | Use this to bypass **Rate Limiting** or detection. |
| **-o** | **Output** | Saves results to a file. | Always save results: -o results.txt. |

## Conclusion and Cheatsheet

**Conclusion**

Gobuster is a critical tool for mapping the **Attack Surface** of a target. By effectively utilizing its three modes, a security professional can uncover administrative panels, backup files, development subdomains, and hidden virtual hosts that may contain vulnerabilities. The power of Gobuster lies in the quality of the **Wordlist** used and the correct application of **Filtering Flags** to eliminate noise and identify actionable targets.

**Fast Revision Cheatsheet**

- **dir mode:** Enumerates files/folders. Requires **-u** and **-w**.
- **dns mode:** Enumerates subdomains. Requires **-d** and **-w**.
- **vhost mode:** Enumerates virtual hosts on an IP. Use **--exclude-length**.
- **Standard Wordlists:** Found in /usr/share/wordlists/ (e.g., Dirbuster, SecLists).
- **Status Code 200:** Success/Found.
- **Status Code 403:** Forbidden (Path exists, but no access).
- **Status Code 404:** Not Found.
- **Status Code 301/302:** Redirect (Use **-r** to follow).
- **-x Flag:** Always check for common extensions like .bak, .config, or .env.